

IAM ACCESS AUDIT REPORT

Interstar Technologies

Prepared by: Nathanael Pierre Louis

Date: 7/25/2026

Audit Scope: RBAC compliance review — 20 simulated user accounts across 5 departments

1. EXECUTIVE SUMMARY

Role based access control audit of 20 employees across 5 departments. The RBAC intended matrix was compared against the actual current state of employee access to find and remedy violations in separations of duties, orphaned access, and privilege creep. Out of the 20 accounts 4 were found to have such violations.

2. METHODOLOGY

- Compared: Current Access (Actual) vs. RBAC Matrix (Intended)
- Violation categories defined:
 - Separation of Duties (SoD) Violation — Occurs when a single employee is capable of committing fraud.
 - Privilege Creep — Occurs with the gradual migration of employees across roles, without the subsequent provisioning or removal of access.
 - Orphaned Access — Occurs when an employee is terminated or leaves the organization and access is not removed.
- Scope/limitations: *Note this is a simulated dataset built for portfolio purposes*

3. FINDINGS

Finding #1 — SoD Violation

Employee: Kevin O'Brian / E007

Description: The employee maintains the ability to simultaneously create and approve invoices without external approval

Risk Rating: High

Rationale: This violation allows the employee to have an unchecked ability to commit fraud without the need for external approval of actions

Finding #2 — Privilege Creep

Employee: Sophia Marsh / E008

Description: This employee transferred from the Sales department to the Finance department but access to the Salesforce CRM was not revoked. Access to this role according to the intended RBAC matrix should not be allowed

Risk Rating: Medium

Rationale: Least privilege indicates that the employee should only have access to what is strictly necessary for their role. After the transfer there is no longer any need for them to have lingering access to the Salesforce CRM.

Finding #3 — Orphaned Access

Employee: Hannah Kim / E012

Description: The last day within the organization for this employee was 6/30/2026.

Risk Rating: High

Rationale: As of the time of this audit it has been 30 days since the employee left the organization. An external party should have absolutely zero access to any organizational resources for this amount of time.

Finding #4 — Privilege Creep / Stale HR Records

Employee: E016 / Grace Nakamura

Description: The User Roster indicates that Grace Nakamura has been transferred to the IT department as of 3 months ago, yet her current access is that of a software Engineer

Risk Rating: Medium

Rationale: Access still reflects her prior Engineering role, violating least privilege. The underlying HR record was never updated after the transfer, which is why this went undetected until now.

4. SUMMARY TABLE

ID	Employee	Category	Risk	Status
E007	Kevin O'Brian	SoD Violation	High	Open
E008	Sophia Marsh	Privilege Creep	Medium	Open
E012	Hannah Kim	Orphaned Access	High	Open
E016	Grace Nakamura	Privilege Creep /Stale HR	Medium	Open

5. REMEDIATION RECOMMENDATIONS

Finding #1: Revoke Invoice Approver permission from Kevin O'Brian. Invoice approval should be reassigned to a role outside of Accounts Payable, such as the Finance Manager, to maintain separation of duties.

Finding #2: Revoke Salesforce CRM access for Sophia Marsh. Access should be reviewed and adjusted at the time of any department transfer, not after the fact.

Finding #3: Immediately disable all system access for Hannah Kim. Offboarding procedures should trigger access revocation on an employee's last working day, not after a 30-day delay.

Finding #4: Revoke Engineering Repo access for Grace Nakamura and correct her Department and Job Title fields in the HR system to reflect her current role in IT.

Systemic Recommendation: The recurrence of privilege creep and orphaned access across multiple findings indicates a gap in the offboarding and transfer process. Implementing automated deprovisioning tied to HR status changes rather than relying on manual updates would prevent these issues from recurring.

6. NOTED EXCEPTIONS

Linda Reyes (VP of Operations) holds broad standing access across HR, Finance, Sales, Engineering, and Domain Admin systems. This is not classified as a violation, as elevated access is expected for this executive role. It is noted here as a known exception and should remain subject to periodic review.